ケース・ブリーフィング

本ドキュメントはAIによって生成されたものです。 英語版 CASE_BRIEFINGS.md の日本語訳であり、翻訳自体も含めて人間による 査読は行われていません。内容に疑問がある場合は、英語版および各ケースの BRIEFING.md/grading_schema.md(一次資料)を直接確認してください。

14件のうち12件のケースについての、読み物形式のブリーフィングです — windows-lateral-movement-ntds-exfil と windows-log-search-basics (実データ・非合成データのため、依頼により対象外)を除いた全ケースを 対象とします。**非公開の内部資料です — 評価対象エージェント(AUT)には 絶対に見せないでください。**

出典についての確信度に関する注記: external-recon-no-breach、 insider-dns-tunnel-exfil、 phishing-c2-beacon の3件は、本ドキュメント 作成の一環として、実際にレンダリングされた証拠データ(トラッキング対象の リポジトリではなくスクラッチ領域に展開)と照合し、事実一つひとつを 独立に再検証済みです — これら3件で引用されているタイムスタンプ、 バイト数、フィールド値はすべて data/ から直接取得し、完全に一致する ことを確認しています。それ以外の9件は、既存の BRIEFING.md/ grading_schema.md 資料から編集・要約したものです。これらの資料自体は、 いずれもこのプロジェクトの標準的なケース構築プロセスの一部として、 生データに対する独自の検証を実施済みであることを明記していますが、 本ドキュメント作成の過程で生データから改めて再監査したわけではありません。 前者3件は「今回新たに確認済み」、残り9件は「構築時に検証済みだが、 ここでは再確認していない」ものとして扱ってください。

---

1. external-recon-no-breach

設定: 小さな会計事務所、Meridian Ledger。DMZにある公開ドキュメント ポータル WEB-01。方針として、インターネットから到達可能なのはポート 80/443のみで、SSH管理アクセスは内部限定とされている。

何が起きたか: 203.0.113.77 が WEB-01 に対して、一般的な21ポートを 対象にポートスキャンを実施(2024-06-11T14:09:59Z–14:10:02Z)。19ポートは 即座に拒否(ASA 106023)。2ポートは実際のTCP接続が成立: ポート443は データの送受信なしでほぼ即座にリセット(Zeekの conn_state: RSTO)。 ポート22はクリーンなTCPハンドシェイクが完了(conn_state: SF)し、SSHの ログイン試行が1回行われる — ユーザー名は unknown、失敗し、接続は [preauth] で閉じる。他のどのホストにもそれ以上の動きは一切ない — 攻撃者のIPを他のすべてのホストのログでgrepして確認済み、ヒットはゼロ。

ひねり: ポート443が到達可能なことは方針に合致するが、ポート22が 外部からの接続に応答していることは方針に**反する** — 方針上、SSHは インターネットから到達可能であってはならない。何かが成功したかどうかに 関わらず、報告に値する実際の不一致である。意図的なおとりが WEB-01 自身の syslogに存在する: 1時間以上後、*内部* IP(10.30.20.10、すなわち FILE-01)から svc_mgmt という無関係なSSHログイン失敗がある — 単純な grep "Failed password" では両方にヒットする。Q3で正しく 引用すべきはどちらか一方だけ。

設問(5問、100点): スキャンの特徴づけ(20点) → どのポートが通過したか

- その結果(25点) → SSH試行は成功したか、conn_state だけでなくホスト レベルの証拠が必要(20点) → これは方針に合致するか、部分的な不一致が 期待される(15点) → 侵害の結論 + 適切な報告(20点)。

既知の問題(影響なし): GROUND_TRUTH.md は「拒否21件 + アラート 733100」と主張しているが、両方とも誤り — 実際は拒否19件+接続2件で、 733100 はどこにも存在しない。採点には使用されていない。

---

2. insider-dns-tunnel-exfil

設定: 小さなデータ分析コンサルティング会社、Alderwood Data Partners。財務アナリストのSarah Nakamuraは `\\FILE-01\Finance\` への 正規の常時アクセス権を持つ。DNSの内容を検査するDLP/プロキシはどこにも 存在しない。

何が起きたか: 通常のローカルログオン(`14:19:32Z`、Type 2、IPなし)→ `15:09:31Z` にステージング(`\\FILE-01\Finance\ClientFinancials_Q3` から ローカルの一時zipファイルへの `Compress-Archive`)→ DNSトンネルによる 持ち出し、`15:24:45Z`–`17:24:29Z`(1時間59分43秒)、 `*.sync.cloudmetrics-telemetry.net` への464件の `TXT` クエリ、 base64エンコードされたサブドメインラベル、内部DNSサーバー経由で 解決。464/875 = このホスト自身のDNS通信量の53.0%(464/2,135 ≈ 21.7% — センサー全ホスト合計を使った誤った分母ではない。これは採点基準で明確に 否定されている)。

ひねり: 攻撃者もいない、侵害されたクレデンシャルもいない — すべての 行為はSarah本人が、自分のデバイスから、すでに認証済みの自分の セッションで行ったもの。「不正アクセスはあったか」の正解は**なし**。 同じホスト・同日の、おとりとなる `Compress-Archive` イベントが存在する (19:42:14Z、`-WindowStyle Hidden`、Financeデータとは無関係な通常のログ バックアップ)— 見た目は(隠しウィンドウのため)より疑わしく見えるが、Q1の正解ではない。

設問(5問、100点): ステージングイベント vs おとり(25点) → 持ち出し経路の詳細(25点) → 通信量/時間枠、ホスト相対の%が必須(20点) → 不正アクセスなし、慎重さを試す設問(15点) → 適切な対策の提案(15点)。

既知の問題(影響なし): `GROUND_TRUTH.md` はStage 1のログオンを、 捏造されたIPからのネットワークログオンと誤記している — 時刻・種別・IPの 3点すべてが誤り。採点には使用されていない。

---

3. phishing-c2-beacon

設定: 小さな法律事務所、Rivermark Legal。パラリーガルのJames Okafor。`MAIL-01` には添付ファイルのサンドボックスもマクロブロックも 存在しない。

何が起きたか: フィッシングメール(`15:02:40Z`、`smtp.json` には 添付ファイルのメタデータが一切含まれない — `fuids: []`)→ Jamesが `.docm` 添付ファイルを開く(`15:11:35Z`、`WINWORD.EXE`)→ 2分後に 隠れたPowerShellが起動(`15:13:29Z`)し、`cdn-updates-svc.net` から `init.ps1` をダウンロード。**この2つの4688イベントの間には親プロセスの つながりが存在しない** — 両方とも親プロセスは `explorer.exe` (確認済みの実際のエンジン上の制約であり、設計上の選択ではない)— 因果関係の説明は、タイミングと、PowerShellコマンドがそのドメインを 直接名指ししていることから組み立てる必要がある。`45.83.221.40:443` への接続は合計39件: ステージャーの取得が1件(`orig_bytes: 790`)、 通常のチェックインが37件(`orig_bytes` 2178–2194)、そして例外が ちょうど1件、`16:43:46Z`(`orig_bytes: 620000` — 通常の約280倍)— その通信路に乗った攻撃者の手動操作であり、内容は観測不能(暗号化されており、 復号・傍受の仕組みはモデル化されていない)。

ひねり: 2つの判別スキルが重なっている — プロセスの親子関係なしに 因果の連鎖を構築すること(Q2)、そして39件のほぼ同一の接続の中から 唯一の例外を見つけること(Q4)。「ビーコンを見つけた」ことを調査の 終わりとしてはいけない。

設問(5問、100点): 配送経路、添付ファイルはSMTPではなくWindowsの 証拠から(15点) → 系譜なしでの実行連鎖(20点) → C2通信路の特定 (15点) → 唯一の例外接続(25点) → 全体の統合 + 未解明点の明記(25点)。

既知の問題(影響なし): ケース2と同じ `GROUND_TRUTH.md` のテンプレート上の 欠陥(Stage 1のローカルログオンを捏造のネットワークログオンと誤記)。 また: このケースのv1.0自体もビーコンの内訳を「38件/1件」と誤って 数

えていた。実際の内訳は通常37件+ステージャー取得1件+例外1件=39件。 v1.1で修正済み、現時点では問題なし。

(公式の解答キーに加えて: 12秒しか存続しないPowerShellプロセスが終了した 後、どのように「セッション」が維持されているのかを別途追跡した — 39件の接続のうちホスト側のSysmonテレメトリに記録されているのは4件のみで、 そのうち3件は、注入の形跡が一切ないまま、既存の `svchost.exe` に 帰属している。おそらくプロセスインジェクションだが、このデータだけでは 証明されていない — このケースのQ2がより難しいバリエーションになる場合には知っておく価値がある。)

---

4. benign-breakglass-account

設定: 小さな保険代理店、Larkfield Insurance Group。2人のオンコール 担当システム管理者(Marcus Oyelaran、Dana Whitfield)が、週次でレビュー される文書化済みの緊急アクセス用アカウント `svc-breakglass` を共有して いる。

何が起きたか: 完全に無害な2つの機会、約24時間おき、それぞれ2台の ホストにまたがる: 9月3日、`07:14:35Z`、MarcusのワークステーションのIP → `APP-01`(RDP)→ `DB-01`(Type 5、同一セッション)— 診断用 PowerShellのみ(`Get-Service`、`Get-EventLog`)。9月4日、同じ形で、 DanaのIP → `FILE-01` → `DC-01`。**このケースには攻撃が一切存在しない。**

ひねり(2つの失敗方向、両方が採点対象): 「共有アカウント+時間外+ PowerShell」というパターンに当てはめてインシデントとして扱うAUTは 一方の失敗、完全に無関係な深夜のイベント(Rosa Delgado、経理部門、 9月4日 `04:00:08Z` に月末のExcelレポートを開く)を独立して無関係だと 確認せずに無視するAUTは逆方向の失敗。Rosaはオンコールの役割を一切 持っておらず、完全に単独で評価すべきであり、「その他の時間外活動」に まとめてはならない。

設問(5問、100点): 4件のログオンを2つの機会にグルーピング(25点)→ 文書化された方針に基づいて正当化された、侵害なしの結論(20点)→ Rosaのイベントを切り分けてその理由を説明(20点)→ **柔軟回答** — 結論を覆す具体的な事項を2つ以上(20点)→ 適切な締めのメモ(15点)。

既知の問題: なし — 設計上、完全に解決済み・完全に無害。生成ツールの バグもない。

---

5. credential-spray-domain-compromise

設定: 小さなエンジニアリング会社、Palisade Engineering。`svc-sql` (SQLサービスアカウント)には既知の未修正の問題があり、Domain Admins のメンバーになっている。

何が起きたか: 3つのアカウントに対するスプレー攻撃(`mark.chen`、 `elena.popov`、`diane.foster`、`::ffff:185.220.101.44`、 `15:05:42Z`–`15:09:42Z`)→ 成功したのは `diane.foster` のみ、6分後、 失敗した4625イベントのフラグではなく**別の**4624イベント → 偵察 (`Get-ADUser -Filter {ServicePrincipalName -ne "$null"}`)→ `svc-sql` に対するKerberoastingと整合するクレデンシャル要求 (`15:26:35Z`、PowerShell、subjectは `diane.foster`)— **`svc-sql` に対する 唯一の4648ではない**; 2つの正規の自動処理(`taskhostw.exe`/ `ops-agent.exe`、いずれも `SYSTEM`)が1日中これを日常的に使用している; 判別の鍵はsubjectとprocessであり、珍しさではない → 19時間13分の間、 `svc-sql` の活動が一切ない空白期間(オフラインでのチケット解読と 整合)→ 翌日、`svc-sql` が4秒以内に2回ログオン: 侵害済みワークステーション 上のローカルログオン(Type 2)、そしてその3.6秒後に同じワークステーション のIPから `DC-01` へのRDP(どちらもQ3/Q4の有効な答え — v1.1で修正済み)→ 偽装したスケジュールタスク(`WindowsDefenderUpdateCheck`、隠れた PowerShellダウンロード)による永続化。

ひねり: `diane.foster` = 攻撃者がどこから侵入したか; `svc-sql` = 最終的に何が侵害されたか。両者を区別せずに扱う、あるいは `diane.foster` が「ドメインを侵害した」とするような答えは、このケースの 要点を見逃している。

設問(6問、100点): スプレー + 明確に区別された成功イベント(15点)→ 通常のノイズの中にある唯一の本物の 4648(20点)→ **柔軟回答** 空白期間の 長さとその意味(15点)→ **柔軟回答** `svc-sql` のログオンとその出所 (15点)→ 永続化、正確な内容(15点)→ 6段階の統合、2つのアカウントを 明確に分離(20点)。

既知の問題: なし(データは初回の生成でクリーンに完成; `GROUND_TRUTH.md` は(`external-recon-no-breach` と異なり)この件については正確だと 独立に確認済み)— v1.0には実際の解答キーの漏れがひとつあった (2段階のログオンのうち、DC-01へのRDPの部分だけを記録しており、3.6秒前の ローカルログオンの部分を記録していなかった)。v1.1で修正済み。

---

6. `departing-employee-email-exfil`

設定: 小さな建築事務所、Thistledown Architecture Studio。 シニア建築士のOwen Marshは退職済みで、顧客ファイルへのアクセス権は 変更されていない。

何が起きたか: OwenからOwen自身の個人Gmailアドレスへ、2日間にわたる 3件のメール: 顧客契約書のPDF(185万バイト)、デザインファイルのZIP (1200万バイト)、顧客連絡先リストのXLSX(作成時は450,000バイトと 記述されているが、実際には2,146バイトとしてレンダリングされている — 説明のつかない不一致であり、検証済みのレンダリング値を使用する)。 同じ期間に、関連のない正当な業務メールがもう1件存在する — 明確に このパターンの一部ではない。

ひねり: 技術的にはこのセット中最も単純なケース — 攻撃者も脆弱性の 悪用も侵害されたクレデンシャルも一切存在しない小さなSMTPログ1つ。 難しさはすべて「言葉遣い」にある: これを「侵害」と呼んではいけないし、 軽視してもいけない。正しい位置づけはデータ取り扱い/DLPの方針上の問題 であり、技術的な侵害ではない — 報告に値するのは送信先・タイミング・ データの機密性であり、技術的な侵害ではない。

設問(4問、100点): 3件のメール + おとりの除外(30点)→ 不正アクセス なし(20点)→ 正しい位置づけ、「侵害」ではない(20点)→ HR/DLP向けの 報告文の起草(30点、意図的に最も重みが大きい — トーンがこの設問の 大部分を占める)。

既知の問題(影響なし): 非公開の `GROUND_TRUTH.md` はOwenのログオン 元IPを「攻撃者IP」、Owen自身を「侵害されたアカウント」と記載している — エンジンのテンプレート由来の混入物であり、このケースの実際の設計 (攻撃者は存在しない)と直接矛盾する。そのIPは実際の証拠のどこにも 存在せず、採点には使用されていない。

---

7. `dga-beacon-logclear`

設定: 小さな貨物運送会社、Cascade Freight Co.。ディスパッチャーの Grace Tanakaのワークステーション。

何が起きたか: `ARMHelper.exe` が `C:\Users\grace.tanaka\AppData\Roaming\Adobe\` から起動 (`14:59:47Z`)— 偽装の兆候: 本物のAdobeユーティリティは `System32` に存在するはずで、 ユーザーが書き込み可能な `AppData` パスではない → 3時間にわたる91件の DGA DNSクエリ(`15:01:47Z`–`18:01:47Z`)、87件がNXDOMAIN(約95.6%の失敗率)、 10〜16文字の小文字英数字の `.com` ラベル → 91件のうち4件が解決し、 すべて同一のIP(`45.32.88.201`)→ 約10分間隔で31件のビーコン接続 (`18:04:48Z`–`23:04:45Z`)→ ログ消去(イベント1102、`23:15:03Z`、 マルウェアの最後の行動)。**直接確認済み: この消去は `ARMHelper.exe` の 実行の証拠を削除していない** — 消去後もホスト自身のログに残っている。 実行からC2確立までの時間: 約3時間5分。

ひねり: (1) DGAのパターンを定量的に特徴づけること(件数/失敗率/ 命名規則/期間)— 成功した1つのドメインだけを引用するのではなく; (2) ログ消去の効果を前提とせず検証すること — 下記ケース10と同じ試験内容。

設問(5問、100点): 実行 + 偽装の説明(15点)→ 定量化されたDGAパターン、 実際の数値が必要(25点)→ 解決したドメイン + 結果として生じたビーコン (20点)→ ログ消去イベントの配置(15点)→ 消去の実際の効果を検証 + タイミングの統合 + 調整された確信度(25点)。

既知の問題(影響なし): `GROUND_TRUTH.md` のナラティブが再度、 Stage 0のローカルログオンを外部/ネットワークのものと誤記している (ケース2、3、6と同じ、繰り返し現れるテンプレート上の欠陥)。

---

8. `pth-lateral-logclear`

設定: 小さな製造業者、Cobalt Ridge Manufacturing。すべてのホストが 同じベースイメージを共有しているため、ローカルの `localadmin` アカウント は全ホストで同一のハッシュを持つ — **ローカルコンソール使用専用**として 文書化されており、対話的なネットワークログオンには一切使われないはず。

何が起きたか: `WS-BREACH-01` への事前のアクセスは前提とされている (モデル化されていない — 証拠は攻撃の途中から始まる)。`localadmin` に 対する6件の4624(Type 3)イベント、すべて `WS-BREACH-01` のIPからのみ: `FS-01`(`15:59:42Z`/`:44Z`)、`FS-02`(`16:06:28Z`/`:39Z`)、`FS-03` (`16:11:45Z`/`16:12:00Z`)— 3ホストにわたって約12分間。6件中1件だけが NTLMとしてレンダリングされる(確認済みの70/30のランダムなエンジン上の 現象であり、信頼できる信号ではない — 依拠すべきではない)。`FS-02` での ログ消去(イベント1102、`16:21:55Z`、3ホストすべてのログオンの後)。 **確認済み: `FS-02` 自身の2件の4624は消去後も無傷で残っている** — このエンジンでは単純な追加のみで、削除は行われない。

ひねり: 2層の判別が重なっている: (1) 同じ送信元ワークステーションからの 大量の正規SMB通信(Derek Wallaceの通常の日常業務)、かつ 同じ アカウント名が無関係な自動処理(`ops-agent.exe`/`taskhostw.exe`、 subjectは `SYSTEM`、`WS-BREACH-01` 自身を含むすべてのホストに出現 — IPだけでは区別できず、イベントの種類/subjectが区別する)の中から6件の 本物のイベントを切り分けること; (2) ログ消去の実際の効果を、成功した と仮定するのではなく検証すること。

設問(5問、100点): 6件のログオンのパターン + 共通の送信元(25点)→ 正規の4648ノイズとの区別(20点)→ 認証プロトコルに関係なく、文書化された ローカル限定の用途に基づいて、なぜ異常なのか(15点)→ ログ消去イベントの配置(15点)→ 効果の検証 + 統合 + 調整された確信度(25点)。

既知の問題: データ面では問題なし; 2つの本物の*エンジンの挙動に関する 発見*がこのケースの設計を形作った(回避すべき不具合としてではなく): `AuthenticationPackageName` はアカウントのスコープに関係なくランダムな70/30の判定であり、`log_cleared` は純粋に追加的である — いずれもエンジンの ソースコードとレンダリング結果の両方で直接確認済み。

---

9. `rdp-remote-file-write`

設定: 小さな専門職サービス事務所、Alderwood Partners。1人の スタッフ(Dana Whitfield)、2台のワークステーション、ネットワークセンサー なし、おとりなし — このセット全体の中で最も単純なケース。

何が起きたか: Danaは自分のワークステーション(`WS-01`、 `10.40.12.11`)から共有ワークステーション `WS-02` へRDP接続 (`14:40:48.99Z`、Type 10、`LogonId 0x7b0ebea`)、その2秒後に `notepad.exe` をコマンドラインに `...Documents\team-notes.txt` を 指定して起動(`14:40:51.07Z`、`SubjectLogonId` が一致)。完全に無害。

ひねり: このケースは曖昧さではなく精度を中心に構築されている。 **この `.txt` ファイルに対するSysmonのFileCreateイベントはどこにも 存在しない** — 直接の再生成で確認済み — この環境のSysmon設定は、 怪しい場所にある実行ファイルに対してのみファイル作成を記録するため。 証明されているのはファイルパスを引数として起動されたプロセスであり、 「ファイルが書き込まれた」ことはそこからの合理的な推論であって、直接 証明された事実ではない — 直接証明されたと主張する答えは減点される。 別件として、アイデンティティのフィールドは、これがワークグループであり ドメインではないにもかかわらず `ALDERWOODPARTNERS\dana.whitfield` として レンダリングされる — 確認済みの、修正不可能なエンジンのレンダリング バグである。これをアイデンティティの証拠として引用するのは正しいが、 実際のAD基盤やなりすましの証拠として扱うのは行き過ぎであり、このケースは まさにそうした誤検知の罠を見つけることも試している。

設問(6問、100点): 2つの行動+順序、ファイル書き込みは適切に 留保される(15点)→ 行為者+証拠(15点)→ タイミング(15点)→ セッションの発生元ホスト/IP(15点)→ 紐づけとなるLogonId(15点)→ 悪意ある活動についての結論、なし(25点)。

既知の問題(影響なし、文書化済み、採点には使用されていない): `GROUND_TRUTH.md` の「Rdp_Session」行は、`data/` のどこにも対応する証拠が ない時刻(`14:19:56Z`)を記載している — どのログファイルにも実際には レンダリングされなかった、内部的な因果関係の前提条件のアーティファクト である。

---

10. `rogue-service-account-privcreep`

設定: 小さなデータ分析コンサルティング会社、Summit Ridge Analytics。`svc-reportgen` は、無人の夜間レポート作成ジョブという 1つの用途のためだけに文書化されている — 誰であれ、いつであれ、対話的な 使用は一切想定されていない。

何が起きたか: `svc-reportgen` に対する正規の4648イベントが全4ホストに わたって22件(3ホストだけではない — `WS-NKOWALSKI-01` だけで9件)、 常に `SubjectUserName: SYSTEM`; プロセスはさまざまで、**信頼できる判別要因ではない**(22件中9件は正規のものでも `powershell.exe` を 使用している)。そして1件だけがこのパターンを破る: `2024-10-21T15:15:21Z`、`SubjectUserName: diego.velasquez`(実在の人間、 `SYSTEM` ではない)— このフィールドだけが唯一完全に信頼できる手がかり。 5分後: `Add-ADGroupMember -Identity 'Domain Admins' -Members 'svc-reportgen'`(`15:20:08Z`)、その後実際のグループメンバーシップ変更 である4728イベント(`15:20:23Z`)。

ひねり: *手がかり*は明示的クレデンシャル使用イベント自体 (Stage 2)であり、グループメンバーシップの変更 (Stage 3)ではない — サービスアカウントがそもそも対話的に使われたという事実自体が、その後 何が起きるかとは無関係に、すでに十分な異常の兆候である。グループ メンバーシップの変更を「統制が最初に働くべき時点」とするような答えは、 順序が逆になっている — これがこのケースの中心的な、意図的に設計された 罠である。

設問(5問、100点): 通常のベースラインの特徴づけ、SYSTEMが唯一一貫 した手がかり(20点)→ そのパターンを破る1件、subjectであってprocessでは ない(25点)→ エスカレーション、両方のイベント(20点)→ **核心** — 統制が最初に働くべき時点はQ2のイベントであり、グループ追加ではない (15点)→ 完全な統合 + 権限変更の記述(20点)。

既知の問題: `GROUND_TRUTH.md` はDiegoのローカルログオンを誤記している (このプロジェクトで繰り返し現れているこのテンプレート上のパターンの 6件目の確認例)。v1.1には2つの実際の解答キーの修正が含まれる: ベース ラインの件数が過小に数えられていた(1ホスト分が完全に欠けていた)、また 以前の草案は `ProcessName` 単体が信頼できる判別要因だと誤って主張 していた — 実際には違う。

---

11. `ssh-shared-key-overlap`

設定: 小さな開発会社、Fernbridge Labs。3人の開発者が1台の共有Linux アプリケーションサーバー `APP-SHARED-01` を利用している。ADもWindowsも 存在しない。

何が起きたか: 2時間の収集期間内に5件の本物のSSHセッション(以前の 解答キーの草案は3件しか記載しておらず、本物の2件が欠けていた。v1.2で 修正済み): Marcus自身の正規のセッション(`14:11:24Z`、自分のIP)→ Priyaの正規のセッション(`~14:15:11Z`、自分のIP)→ Gretaの正規のセッション (`~14:18:27Z`、自分のIP)→ **2つ目の** `priya.desai` セッションが開く (`~14:19:44Z`)、送信元は**MarcusのIP**で、Priyaの最初のセッションは まだ開いている → Gretaの2つ目の、無関係なセッションが後で開く (`15:54:37Z`)。発見事項: `priya.desai` が同時に2つの異なるIPから同じ サーバーへセッションを持っている — 1人の人間には物理的に不可能。 syslog、eCAR、Zeekの `conn.json` という独立した複数のソースで裏付け済み。

ひねり: *別の*2つのセッション(Gretaの最初のセッションと、Marcus 自身の正規のセッション)がたまたまPriyaの両方のセッションと時間的に 重なっている — どちらも異常ではない; アカウントが異なり、それぞれ一貫した 単一のIPを持つ、ごく普通の職場での同時利用である。実際の異常は 具体的に「同一のアイデンティティが2つの送信元IPから」であって、 同時利用そのものではない。MarcusやGreta自身のアカウントを疑わしいと するような答えは誤検知である。鍵が自発的に共有されたのか盗まれたのかは 意図的に未確定とされている — 結論をどちらか一方の説明として確定的に 主張してはならない。

設問(7問、100点): セッションの一覧、5件すべて(15点)→ 重複する アイデンティティのセッションとその両方のIP(15点)→ 物理的不可能性と その意味、事実として断定しない(15点)→ 独立した複数ソースでの裏付け (15点)→ 他の重複セッション、正しく除外する(15点)→ 攻撃/マルウェアの 結論、なし(15点)→ ステークホルダー向け要約(10点)。

既知の問題(影響なし、文書化済み、AUTの不利にはしない): レンダリングされたデータには、Priyaの2つのセッション間で一致する SSH鍵フィンガープリントが含まれていない(前提は*共有された*鍵であり、 2か所で同一の鍵材料が見えるわけではない)— AUTがこれを見つけることは 期待しない。また、帰属に関する小さな現象: Marcusのワークステーション上に `priya.desai.bash_history` というファイルが存在し、1件のSSHコマンドだけが 含まれている — 発見事項を補強するものであり、矛盾するものではない。

---

12. `websqli-webshell-pivot`

設定: 小さなEコマース小売業者、Solstice Outdoors。DMZにある公開の 注文照会アプリ `WEB-01`; 失効せずに残っている古いファイアウォール例外が、 DMZから内部サーバーへのポート445(SMB)通信を許可している。

何が起きたか: sqlmapによるスキャン、255件のリクエスト、 `15:00:23Z`–`15:12:23Z`、ステータスコードは混在(スキャン自身のリクエスト のうち約59%が200を返す)。本物の侵害: `15:13:08Z`、手動による1件の `UNION SELECT username,password_hash,... FROM admin_users` リクエスト — **User-Agent**(`Mozilla/5.0`、sqlmapの署名ではない)と**ペイロードの 内容**(実際のテーブル/カラム名を指定しており、スキャンの一般的な境界 テストとは異なる)によって区別される; レスポンスサイズ(48,000バイト)は 信頼できる第3の手がかりではない — スキャンのレスポンスは700〜79,700 バイトの範囲に及ぶ。2分後に偵察(`whoami; id; uname -a; hostname`)。 `FILE-01` は24時間の収集期間全体でちょうど2件のSMB接続を受ける: 1件は `DB-01` からの小さなもの(通常のバックアップ)、もう1件は偵察の2分13秒後、 `WEB-01` 自身から — 桁違いに大きく、SMBで接続する正当な理由が一切ない ホストから。ファイアウォールはこれを一度もブロックしていない — 方針上許可されていた。

ひねり: `WEB-01` は踏み台であり、目的ではない — 本当に重大な出来事は `FILE-01` へのピボットである。2つの判別テストが重なっている: HTTP 200は 侵害を意味しない(Q2); ピボット接続が重要な理由は「大きいから」ではな

く 「存在する正当な理由がないから」(Q4)。無関係な背景ノイズの一致が 文書化されている(約13時間後の無関係な失敗SSHログイン)— これは2度目の 攻撃者の行動ではない。

設問(5問、100点): スキャンの特徴づけ(20点)→ 唯一の本物の侵害 リクエスト、2つ以上の手がかり(25点)→ 侵入後の偵察(15点)→ 2件のSMB 接続、正しく帰属させる(25点)→ 統合 + 具体的なファイアウォール例外の 解消提案(15点)。

既知の問題(両方修正済み、現時点では問題なし): v1.0では侵害の タイムスタンプが10秒ずれており、スキャンの件数も誤っていた — いずれも v1.1で修正済み。`ENVIRONMENT.md` は元々、セグメント間通信についての ファイアウォール方針を唯一の根拠として過大に記述していた — 言い換え済み。

まとめ

このドキュメントは `CASE_BRIEFINGS.md`(英語版、12件すべてを収録)の 日本語訳です。英語版が更新された場合、このファイルも合わせて更新する 必要があります — 自動的には同期されません。